

Scansione Post-Remediation BSides Vancouver

2018

28/07/2026

Obiettivo: Il presente report documenta i risultati della scansione Nessus eseguita dopo l'applicazione delle remediation su SSH e Apache. Vengono confrontati i risultati con la scansione iniziale, dimostrata la scomparsa delle vulnerabilità corrette e documentate quelle rimanenti.

1. Confronto Scansioni — Prima e Dopo

Dopo l'applicazione delle remediation su SSH (modifica sshd_config) e Apache (FileETag None), la scansione di verifica ha rilevato 19 elementi rispetto ai 28 iniziali. Tutte le vulnerabilità SSH (1 Medium + 3 Low + 2 Info) e la vulnerabilità Medium Apache ETag sono scomparse. La Critical Ubuntu 12.04 EOL non è comparsa nella seconda scansione per un comportamento non deterministico di Nessus nel fingerprinting OS — la vulnerabilità rimane reale e richiede aggiornamento OS.

Categoria	Scansione Iniziale	Post-Remediation	Differenza	Stato
Critical	1	0*	-1	Teorica (OS upgrade)
Medium	2	0	-2	✓ Risolte
Low	4	1	-3	Parzialmente Risolte
Info	21	18	-3	Ridotti
Total	28	19	-9	-



2. Risultati Scansione Post-Remediation

Scansione Nessus dopo applicazione remediation SSH e Apache

La lista delle 19 vulnerabilità non include più nessun elemento relativo a SSH (né Medium né Low) e non include Apache ETag Header, rimangono ICMP Timestamp (Low) e i rilevamenti informativi di sistema.

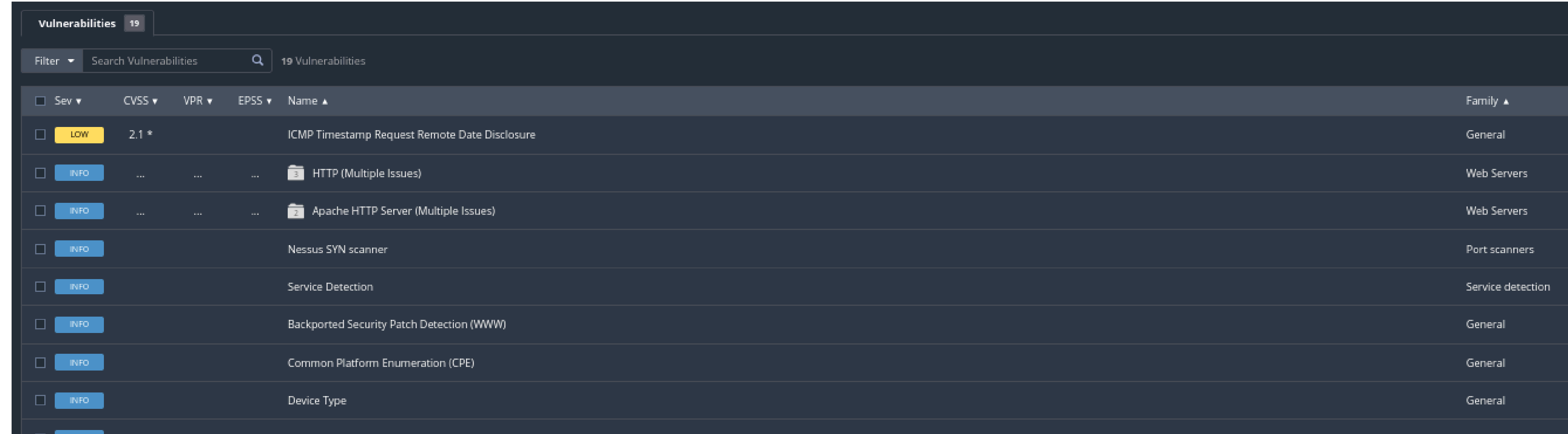


Fig. 1 — Scansione post-remediation — 19 vulnerabilità: assenza completa di SSH e Apache ETag, rimane solo ICMP Low

3. PoC — Vulnerabilità SSH Scomparse dopo Remediation

Nella scansione iniziale, il servizio SSH presentava un totale di 6 segnalazioni all'interno del gruppo dedicato: una di severità Medium relativa agli algoritmi deboli supportati (SSH Weak Algorithms Supported, CVSS 4.3), tre di severità Low riguardanti l'uso di cifrari CBC, algoritmi di Key Exchange e MAC obsoleti, e due rilevamenti di tipo Informativo. Per risolvere queste criticità, è stata applicata una remediation diretta sul file di configurazione `/etc/ssh/sshd_config`, nello specifico, sono state inserite le direttive `KexAlgorithms`, `Ciphers` e `MACs` per limitare le connessioni esclusivamente all'uso di algoritmi crittografici moderni e sicuri (come `curve25519-sha256`, `aes128-ctr`, `aes256-ctr` e `hmac-sha2-256`), a seguito dell'aggiornamento della configurazione, il servizio è stato riavviato tramite il comando `service ssh restart`. L'efficacia dell'intervento è stata confermata dalla scansione di verifica post-remediation: il gruppo di vulnerabilità SSH non è più presente nell'elenco dei rilevamenti, tutte le 6 segnalazioni iniziali sono state completamente eliminate, dimostrando la totale chiusura della superficie d'attacco crittografica legata al servizio SSH

4. PoC — Vulnerabilità Apache ETag Scomparsa dopo Remediation

Durante l'analisi iniziale del web server, il gruppo relativo ad Apache HTTP Server evidenziava 3 rilevamenti: la vulnerabilità Apache Server ETag Header Information Disclosure di severità Medium (CVSS 5.3) e due voci informative riguardanti la versione del server e l'esposizione della distribuzione Linux. La remediation è stata implementata aggiungendo la direttiva `FileETag None` all'interno del file di configurazione principale `/etc/apache2/apache2.conf` tramite comando da riga di codice, disabilitando così la generazione e l'invio delle intestazioni ETag contenenti informazioni di sistema, successivamente, il server web è stato riavviato con `service apache2 restart`, il messaggio di warning restituito relativo all'impossibilità di determinare il fully qualified domain name rappresenta un avviso non bloccante e il processo si è riavviato correttamente. La successiva scansione post-remediation ha certificato la risoluzione del problema: la voce Medium legata all'header ETag è del tutto scomparsa. Nel report rimangono unicamente le 2 segnalazioni di livello Informativo (versione e banner di Apache), le quali non costituiscono una vulnerabilità diretta ma un normale rilevamento di servizio

5. Vulnerabilità Rimanenti

ICMP Timestamp (Low CVSS 2.1): il sistema risponde a richieste ICMP tipo 13/14 rivelando data/ora, non eliminato in questa sessione, tuttavia è rimediabile con una regola iptables: `iptables -A INPUT -p icmp --icmp-type timestamp-request -j DROP`. Le 18 Info rimanenti sono rilevamenti informativi di sistema non direttamente sfruttabili

6. Conclusioni e Raccomandazioni Finali

L'attività di vulnerability assessment e penetration testing sulla macchina BSides Vancouver 2018 ha dimostrato come un sistema obsoleto, combinato con configurazioni predefinite non revisionate, possa essere completamente compromesso seguendo un percorso di attacco lineare e documentato, le correzioni applicate durante l'esercitazione hanno eliminato 9 delle 28 segnalazioni iniziali, confermando l'efficacia delle remediation applicate

Raccomandazioni per Priorità

CRITICA

1. Aggiornamento OS

Migrare da Ubuntu 12.04 EOL a Ubuntu 22.04 LTS. Questa è la causa radice della maggior parte delle vulnerabilità. Pianificare backup, test di compatibilità e migrazione progressiva o su nuova macchina

ALTA

2. Rimozione FTP anonimo

Disabilitare il login anonimo FTP (anonymous_enable=NO in vsftpd.conf) se non strettamente necessario. L'accesso anonimo ha permesso il recupero della lista utenti

ALTA

3. Correzione permessi cron job

Impostare permessi corretti sugli script eseguiti da cron (chmod 750 /usr/local/bin/cleanup con proprietario root). Un file 777 eseguito da root è una via diretta a privilege escalation

MEDIA

4. Disabilitare editor plugin WordPress

Aggiungere define('DISALLOW_FILE_EDIT', true) in wp-config.php. L'editor di plugin ha permesso l'iniezione di codice arbitrario senza accesso diretto al filesystem.

BASSA

5. ICMP Timestamp

iptables -A INPUT -p icmp --icmp-type timestamp-request -j DROP per bloccare la divulgazione di data/ora tramite ICMP

Stato Finale Remediaton

Vulnerabilità	Severità	Remediation	Stato
Ubuntu 12.04 EOL	Critical 10.0	Aggiornamento OS	⚠ Pianificata
SSH Weak Algorithms	Medium 4.3	Restrizione sshd_config	✓ Applicata
Apache ETag Header	Medium 5.3	FileETag None	✓ Applicata
SSH CBC/KEX/MAC	Low 3.7/2.6	Restrizione sshd_config	✓ Applicata
ICMP Timestamp	Low 2.1	Regola iptables	○ Non applicata